Báo cáo Chương 4 — Dynamic Analysis / Fuzzing

Mục lục

1. Mã nguồn tùy chỉnh (tab 'Mã tùy chỉnh') **2**

2. Kết quả phân tích động **2**

1. Mã nguồn tùy chỉnh (tab 'Mã tùy chỉnh')

Mã nguồn Python

```
def target_func(a, b):
"""Ham muc tieu cho Black-box Fuzzer.
Ten ham PHAI la 'target_func'.
Khai bao kieu tham so tuong ung o o "Kieu tham so" ben duoi,
vi du: int,int hoac str,int"""
return a // b
```

2. Kết quả phân tích động

 PHÂN TÍCH TỰ ĐỘNG mục tiêu fuzzing (C): 3 hàm
→ calc_expand_capacity_v0(current_cap:int, factor:int) — fuzz được
độ phức tạp 1 (nhánh 0, vòng lặp 0, switch 0); so sánh hằng số: 0; SMT: dịch được
realloc_buffer_leak_v0(old_size:int, new_size:int, simulate_oom:int) — fuzz được
độ phức tạp 4 (nhánh 3, vòng lặp 0, switch 0); so sánh hằng số: 0; SMT: không (khai báo con trỏ/mảng chưa hỗ trợ)
API đáng chú ý: malloc (cấp phát heap (rò rỉ / kích thước lớn)); realloc (cấp phát lại (dangling pointer)); free (giải phóng bộ nhớ (double-free / use-after-free))
cleanup_and_read_uaf_v0(val:int) — fuzz được
độ phức tạp 2 (nhánh 1, vòng lặp 0, switch 0); so sánh hằng số: 0; SMT: không (khai báo con trỏ/mảng chưa hỗ trợ)
API đáng chú ý: malloc (cấp phát heap (rò rỉ / kích thước lớn)); free (giải phóng bộ nhớ (double-free / use-after-free))
Gợi ý kỹ thuật fuzzing (☑ = nên chọn):
☑ Boundary điểm 78 — luôn nên có: thử biên 0, ±1, INT_MIN/MAX, chuỗi rỗng/dài; có tham số số → lỗi tràn/chia 0 thường nằm ở biên
☑ Mutation điểm 62 — đột biến từ seed, hiệu quả khi đã có input 'gần đúng'; có 14 seed từ test case Ch2/3/5
☑ Black-box điểm 57 — ngẫu nhiên thuần, rẻ, dùng làm mốc so sánh; hàm đơn giản (ít nhánh) → ngẫu nhiên đã đủ phủ
☐ White-box (concolic) điểm 40 — dịch hàm → SMT/Z3 sinh input phủ từng đường đi; cộng từ điển hằng số
☐ Coverage-guided điểm 35 — giữ input làm tăng coverage → khám phá nhánh sâu; ít nhánh → lợi ích thấp
Sanitizer gợi ý: auto — có số nguyên → UBSan bắt tràn số nguyên có dấu (hành vi không xác định)
Ngân sách gợi ý: 140 input/kỹ thuật; có 14 seed từ test case Ch2/3/5

→ Xem danh sách gợi ý bên trái, chỉnh lại nếu muốn rồi bấm '▶ Chạy chiến dịch'.